Leveraging AI Assistants to Automate Security Testing and Remediation

Jeffery Payne | Chief Executive Officer |

jeff.payne@coveros.com

Jeffery Payne

Jeffery Payne is CEO and founder of Coveros, Inc., a company that helps organizations accelerate software delivery using agile methods. Prior to founding Coveros, he was the co-founder of application security company Cigital, where he served as CEO for 16 years.

Jeffery is a recognized software expert and popular keynote speaker at both business and technology conferences on a variety of software quality, security, DevOps, and agile topics. He has testified in front of congress on issues such as digital rights mgmt., software quality, and software research.

Jeffery is the technical editor of the Stickyminds community (www.stickyminds.com)

WHO WE ARE

Better Software. Faster.

Coveros equips organizations to modernize software delivery while optimizing business value.

We offer consulting, coaching, and training for enterprises, teams, and individuals, and host leading AI, Software Development, and Testing Conferences.

Coveros is a GitHub Premier and Microsoft Azure Accelerate Partner

Our Services

Software Transformation

Services to help you modernize your software process by improving agility, continuous delivery, test automation, and application security leveraging AI

Software Development

AI-enabled services to support the planning, design, development, testing, and delivery of secure, reliable software applications.

Immersive Learning

50+ hands-on training classes taught publicly and privately

Enterprise, team, and individual coaching to reinforce concepts

What is AI-Assisted Security Testing?

GitHub Copilot

tabnine

codeium

Amazon CodeWhisperer

The process of leveraging Generative AI capabilities to assist in the security testing of software.

CURSOR

codota

Continue

The Good, The Bad, and The Ugly

By 2028, 90 percent of enterprise software engineers will use AI code assistants.

Gartner®

80% of development teams express fear regarding the security threats of AI-generated code.

Over 40% of AI-generated code contains security flaws.

The Bottleneck

- **The Velocity Gap: Development moves at 100mph; traditional security reviews move at 10mph.**
- **The "So What?" Problem: Vulnerability scanners provide a "what," but developers need the "why" and "how to fix.“**
- **The Fatigue Factor: Managing massive security debt leads to burnout and risky shortcuts.**

AI as the Security Pair Programmer

- **Shift from Reactive to Proactive: Moving beyond static analysis to conversational context.**
- **The Copilot Advantage: How LLMs understand intent and logic, not just syntax patterns.**
- **Integration Points: Where AI fits into the SDLC (IDE, PR reviews, CI/CD).**

The Art of Security Prompt Engineering

- **Context is King: Why "Fix this bug" fails, but "Fix this SQL injection using parameterized queries" succeeds.**
- **Role-Based Prompting: Instructing the AI to act as a "Senior Security Auditor.“**
- **Iterative Refinement: Using a multi-turn conversation to narrow down false positives.**

The Hallucination Hurdle and HITL

- **Trust but Verify: Why AI-generated security fixes must still be reviewed.**
- **Common Pitfalls: Deprecated libraries, "insecure-by-default" suggestions, and logical blind spots.**
- **Policy & Governance: Setting guardrails for using AI-generated code in production.**

A Framework for Integration

- **Step 1: Audit current workflows for "low-hanging fruit" (e.g., unit test generation).**
- **Step 2: Standardize a "Security Prompt Library" for your team.**
- **Step 3: Establish a "Human-in-the-loop" (HITL) verification gate.**

Conclusions: The Future of Defensive AI

- **Turning the Tide: AI empowers developers to be their own first line of defense.**
- **Trust but Verify!**
- **Key Takeaway: AI doesn't eliminate the need for security experts; it allows them to focus on complex architecture instead of repetitive fixes.**

QUESTIONS?

jeff.payne@coveros.com

Thank you!

coveros